

OWASP ZAP: 6 Key Capabilities and a Quick Tutorial

What is OWASP ZAP?

[OWASP](#) ZAP is a penetration testing tool that helps developers and security professionals detect and find vulnerabilities in web applications. OWASP ZAP performs multiple security functions including:

- Passively scanning web requests
- Using dictionary lists to search for files and folders on web servers
- Using crawlers to identify a site's structure and retrieve all links and URLs
- Intercepting, displaying, modifying, and forwarding web requests between browsers and web applications

OWASP ZAP can identify vulnerabilities in web applications including compromised authentication, exposure of sensitive data, security misconfigurations, SQL injection, cross-site scripting (XSS), insecure deserialization, and components with known vulnerabilities.

6 Key Capabilities of the OWASP ZAP Tool

ZAP sits between a web application and a penetration testing client. It works as a proxy—capturing the data transmitted and determining how the application responds to possibly malicious requests. Professionals of various skill levels and job roles can use OWASP ZAP.

1. Active vs. Passive Scans

ZAP offers two types of scans—active and passive. Passive scans check HTTP requests and application responses for known indicators of security vulnerabilities and cannot make changes to requests. Active scans can create and modify requests sent to the application, sending test requests that surface vulnerabilities you cannot catch using a passive scan.

Active scans are generally considered more effective in finding application vulnerabilities because the testing suite injects various requests that surface vulnerabilities. However, these scans actively attempt to attack the application and might create or delete data.

Passive scans pose a low risk, as they cannot change the data. However, these scans cannot catch many vulnerabilities, including aggressive vulnerabilities like SQL Injection (SQLi).

2. Running Scans: Desktop vs. API

You can deploy OWASP ZAP as a desktop application or automatically via an API, depending on how you intend to use ZAP. Security analysts and penetration testers often run a one-off test utilizing the desktop application to detect vulnerabilities. Software development and security teams usually deploy ZAP via automation to ensure regular security testing of the application and its APIs.

3. Authenticated Security Scanning

Many web applications require authentication. In this case, authentication must be configured in ZAP before running the scan. Otherwise, the check will not test any paths or paths that are behind authentication protection.

ZAP supports a variety of authentication formats, including form-based authentication, script-based authentication, JSON-based authentication, and HTTP/NTLM-based authentication.

4. WebSockets

WebSockets create an asynchronous communication channel between client and server, transmitting data in full duplex. This creates security vulnerabilities, because the WebSocket keeps the channel open, allowing attackers to eavesdrop or hijack the session. ZAP continuously scans WebSockets to identify vulnerabilities.

5. OWASP ZAP Fuzzer

Fuzzing is a technique that sends large volumes of unexpected data inputs to a test application. OWASP ZAP enables fuzz testing of web applications. You can choose one of the built-in payloads, download a variety of payloads provided by the ZAP community, or create your own.

6. AJAX Spidering

In a penetration test, AJAX scraping can help detect requests from AJAX rich web applications that normal crawlers cannot detect. ZAP provides an AJAX Spider window, accessible through the tools menu. The tool has configuration parameters such as maximum crawl depth, maximum crawl status, maximum duration, and other options to avoid infinite crawls.

OWASP ZAP Tutorial: Installation and Initial Configuration

This is abbreviated from the official OWASP ZAP [tutorial](#).

Prerequisites

- ZAP has installers for Windows, Linux, and Mac OS/X, as well as Docker images. Download the appropriate installer from the [download page](#) and install it on the machine where you will run the penetration test.
- Java 8 or higher is required to run ZAP. The Mac OS/X installer includes the appropriate Java version, but Java 8+ must be installed separately for Windows, Linux, and cross-platform versions. The Docker version already includes Java.
- When you start ZAP for the first time, you need to choose whether to make the ZAP session persistent. If you persist the session, it will be saved to a local HSQLDB. Otherwise, files will be deleted when you log out of ZAP.
- Before proceeding, ensure you have permission from the web application owner to perform a penetration test.

Run a quick start auto scan:

1. Start ZAP and click the **Quick Launch** tab in the workspace window.
2. Click the **Auto Scan** button.
3. In the **Attack URL** text box, enter the full URL of the web application.
4. Select either **Use traditional spider**, **Use ajax spider**, or both (more details below)
5. Click **Attack**.



Image Source: [OWASP](#)

ZAP uses a crawler to go through the web application and scan pages it finds. It then uses the active scanner to attack every page, function, and parameter it finds.

ZAP spiders

ZAP provides two spiders for scraping web applications, which you can select in the automated scan dialog:

- **The traditional ZAP spider** inspects HTML in a web application's response to detect links. Although this spider is fast, it is less effective when navigating AJAX web applications that use JavaScript to generate links.
- **The ZAP AJAX spider** is more effective for JavaScript applications. It navigates a web application by invoking a browser, rendering the full JavaScript of the page, and following any links on the resulting page. AJAX spiders are slower than traditional spiders and require additional configuration to be used in a headless environment.

Passive vs. active scanning

ZAP uses two forms of scanning:

- **Passive scanning** investigates all proxy requests and responses, but does not change the response in any way and is considered safe. It can be done on a background thread so it doesn't slow down the application. This can find some vulnerabilities and can help you understand the basic security posture of a web application.
- **Active scanning** attempts to find additional vulnerabilities using known attack vectors against the selected target. Do not use active scans against targets you don't have permission to test, as active scans are real attacks that might cause damage to the

Application Security with HackerOne

HackerOne and the community of ethical hackers is at the forefront of using OWASP to strengthen application security and make the Internet safer, referencing the OWASP Top 10 to prioritize their actions. Taking this approach one step further, the HackerOne Global Top 10 can enable application security teams to increase their effectiveness with timely insights, segmented by industry and fueled by exploitable findings submitted by ethical hackers. These findings are often new or found by innovative techniques and are unlikely to show up in the OWASP database. Combined, OWASP and HackerOne exploit databases assure that high severity vulnerabilities are found and fixed before bad actors can do their work.

Learn more about the HackerOne approach to [Application Security](#)

Company

Leadership

Careers

Partners

Newsroom

Contact Us

Knowledge

Center

Application Security

Penetration Testing

Cloud Security

Hacking

Cybersecurity

Attacks

DevSecOps

Resources

Blog

Documentation

Leaderboard

Partner Portal

Resources

Contacted
by a
hacker?

